

HOUSE BILL 1033

By Dixie

AN ACT to amend Tennessee Code Annotated, Title 20;
Title 29 and Title 47, Chapter 18, relative to data
security.

BE IT ENACTED BY THE GENERAL ASSEMBLY OF THE STATE OF TENNESSEE:

SECTION 1. Tennessee Code Annotated, Title 47, Chapter 18, is amended by adding
the following as a new part:

47-18-3501.

As used in this part:

(1) "Business" means a limited liability company, limited liability
partnership, corporation, sole proprietorship, association, or other group,
however organized, and operating for profit or not for profit;

(2) "Covered entity" means a business that accesses, receives, stores,
maintains, communicates, or processes personal information, personal health
information, or restricted information in or through one (1) or more systems,
networks, or services located in or outside of this state;

(3) "Data breach":

(A) Means an intentional or unintentional act that has the potential
to result in electronic information owned, licensed to, or otherwise
protected by a covered entity being viewed, copied, modified, transmitted,
or destroyed in a manner that is reasonably believed to cause or have the
potential to cause material risk of fraud, identity theft, or other injuries or
damage to person or property; and

(B) Does not include:

(i) Disclosure of personal information, personal health information, or restricted information pursuant to a search warrant, subpoena, or other court order, or pursuant to a subpoena, order, or duty of a regulatory agency; and

(ii) Good faith transmission of personal information, personal health information, or restricted information by the covered entity's employee or business associate, or an agent on behalf of the covered entity; provided, that the personal information, personal health information, or restricted information is not used for an unlawful purpose or subject to further unauthorized disclosure;

(4) "Encrypted" means the use of an algorithmic process to transform data into a form for which there is a low probability of assigning meaning without the use of a confidential process or key;

(5) "Individual" means a natural person;

(6) "Personal health information" means information in the medical record or designated record set that can be used to identify an individual and that was created, used, or disclosed in the course of providing a healthcare service, including diagnosis or treatment, and for which the standards, implementation specifications, and requirements for protecting electronic protected health information are described in 45 CFR 164, subpart C;

(7) "Personal information":

(A) Means information relating to an individual who can be identified, directly or indirectly, in particular by reference to an identifier such as a name, an identification number, social security number, driver's

license number or state identification card number, passport number, account number or credit or debit card number, location data, biometric data, an online identifier, or one (1) or more factors specific to physical, physiological, genetic, mental, economic, cultural, or social identity of such individual; and

(B) Does not include personal health information or restricted information; and

(8) "Restricted information" means information that is sensitive about an individual, other than personal information or publicly available information, that alone or combined with other information can be used to distinguish or trace an individual's identity or can be linked to an individual if the information is not encrypted, redacted, or altered by any method or technology in a manner that renders the information unreadable, and the breach of which is likely to result in a material risk of identity theft or other fraud to a person or property.

47-18-3502.

(a)

(1) A covered entity seeking an affirmative defense under this part shall create, maintain, and comply with a written cybersecurity program that contains administrative, technical, operational, and physical safeguards for the protection of both personal information, personal health information, and restricted information at the time of the breach.

(2) The program must be designed to:

(A) Protect against a breach of security;

(B) Protect the security and integrity of personal information, personal health information, and restricted information;

(C) Protect against any anticipated threat to the security or integrity of personal information, personal health information, and restricted information;

(D) Continually evaluate and mitigate any reasonably anticipated internal or external threats or hazards that could lead to a data breach, including conducting annual privacy and security risk assessments; and

(E) Communicate to any affected parties the extent of any risk posed and actions the affected parties may take to reduce any damages if a data breach is known to have occurred.

(3) The covered entity must have a chief information officer or security officer assigned to coordinate the program and take measures to train employees on the necessary safety practices and regulations.

(b) A covered entity satisfies subsection (a) if the written cybersecurity program contains written protocols that reasonably conform to an industry-recognized cybersecurity framework at the time of the breach, as described in § 47-18-3503.

(c) A covered entity that satisfies this section is entitled to an affirmative defense to any cause of action in tort brought under the laws of this state or in the courts of this state, even if the covered entity's agent breached the covered entity's data, when it is alleged that the failure to implement reasonable information security controls resulted in a data breach of personal information, personal health information, or restricted information.

(d) A covered entity may not claim an affirmative defense under this section if the covered entity had actual notice of a threat or hazard to the security or integrity of the personal information, personal health information, or restricted information and did not act to mitigate the threat or potential hazard within a reasonable time in accordance with

the industry-recognized cybersecurity framework timeframe to make proper notifications to inform affected parties a breach has occurred.

47-18-3503.

(a) A covered entity's cybersecurity program reasonably conforms to an industry-recognized cybersecurity framework for purposes of this part if, at the time of the breach:

(1) The cybersecurity program reasonably conforms to the current version of one (1) or more of the following, subject to subsection (b):

(A) The Framework for Improving Critical Infrastructure Cybersecurity developed by the national institute of standards and technology (NIST);

(B) NIST Special Publication 800-171;

(C) NIST Special Publications 800-53 and 800-53A;

(D) The International Organization for Standardization and International Electrotechnical Commission's 27000 Family of Standards;

(E) The Federal Risk and Authorization Management Program Security Assessment Framework; or

(F) The Center for Internet Security's Critical Security Controls for Effective Cyber Defense; or

(2) The covered entity is regulated by the state, the federal government, or both, or is otherwise subject to, and the cybersecurity program reasonably conforms to, the entirety of the current version of one (1) or more of the following at the time of the breach, subject to subsection (b):

(A) The security requirements of the federal Health Insurance Portability and Accountability Act of 1996 (HIPAA), as set forth in 45 CFR part 164, subpart C;

(B) Title V of the Gramm-Leach-Bliley Act, Pub. L. No. 106-102, as amended;

(C) The Federal Information Security Modernization Act of 2014, Pub. L. No. 113-283;

(D) The Health Information Technology for Economic and Clinical Health (HITECH) Act, as set forth in 45 CFR part 164; or

(E) Another applicable federal or state regulation; or

(3) The cybersecurity framework reasonably complies with both the current version of the payment card industry data security standard and conforms to the current version of another applicable industry-recognized cybersecurity framework, subject to subsection (b).

(b) If a new and final revision to a framework listed in subsection (a) is published, then a covered entity whose cybersecurity program reasonably conforms to such framework shall conform the elements of its cybersecurity program to the revised framework, or another applicable framework listed in subsection (a), within the timeframe provided, if any, in the relevant framework upon which the covered entity intends to rely to support its affirmative defense. In all cases, the covered entity must come into compliance with the new and final revision, or another framework listed in subsection (a) within the earlier of one (1) year after the publication date of the new and final revision or its stated compliance date, if any.

47-18-3504.

This part does not create a private right or cause of action, including a class action, with respect to any act or practice regulated under this part.

SECTION 2. This act takes effect July 1, 2025, the public welfare requiring it.